

Enterprise Security Risk Register

Documented ownership, treatment decisions, review cycles, and residual risk

Purpose

Maintain a repeatable record of cybersecurity risks, business impact, existing controls, treatment actions, accountable owners, target dates, and residual-risk decisions. This sample uses a 5x5 likelihood-impact model.

Risk ID	Asset / Process	Threat & vulnerability	Inherent	Existing controls	Treatment / next action	Residual	Owner	Review
R-001	Privileged access	Credential theft + excessive standing privileges	Critical	MFA for most admins; standard IAM logging	Require phishing-resistant MFA; reduce standing admin; quarterly recertification	Medium	IAM Lead	Monthly
R-002	Internet-facing servers	Exploit of critical unpatched software	Critical	Routine patching; firewall; endpoint protection	7-day critical remediation SLA; authenticated scans; exception approval	High	Infra Lead	Monthly
R-003	Cloud storage	Public exposure from misconfiguration	High	Encryption; cloud IAM	Private-by-default policy; CSPM alerting; change review; access logging	Medium	Cloud Owner	Monthly
R-004	Security monitoring	Missing logs reduce detection coverage	High	Partial SIEM ingestion	Define required log-source standard; onboard admin, identity, endpoint, and cloud logs	Medium	SOC Lead	Monthly
R-005	User accounts	Phishing / password reuse	High	Email filtering; basic MFA	Stronger MFA; awareness simulations; risky-login detection; rapid disable/reset process	Medium	Security	Monthly
R-006	Backups / recovery	Ransomware or corruption affects recoverability	High	Daily backups	Immutable backup copy; quarterly restore tests; recovery evidence and exceptions	Medium	IT Ops	Quarterly
R-007	Third-party SaaS	Vendor compromise or overprivileged integration	High	Contract review	Security questionnaire; SSO/MFA; data minimization; annual access review	Medium	GRC / Procurement	Quarterly
R-008	Endpoints	Malware or unauthorized tooling	High	AV/EDR; patching	Tamper protection; application controls; alert tuning; isolation playbook	Medium	Endpoint Lead	Monthly
R-009	Sensitive data	Improper sharing or exfiltration	High	Access controls; encryption	Classification labels; DLP monitoring; least privilege; user training	Medium	Data Owner	Quarterly
R-010	Incident response	Delayed escalation during severe incident	High	IR plan exists	Tabletop exercise; contact-tree validation; severity criteria; lessons-learned tracker	Medium	Security Lead	Quarterly

Risk Treatment Rules

- **Mitigate:** Reduce likelihood or impact using preventive, detective, or corrective controls.
- **Avoid:** Stop the activity creating unacceptable risk.
- **Transfer:** Shift defined financial or operational exposure through contracts or insurance; accountability is not transferred.
- **Accept:** Business owner explicitly accepts residual risk with rationale, compensating controls, and review/expiration date.

Status & Escalation

- Critical risks require immediate leadership visibility and an active treatment plan.
- High risks require a named owner, target date, and regular status reporting.
- Overdue actions are escalated based on business impact, exposure, and absence of compensating controls.
- Closed risks retain evidence of remediation and validation for auditability.